
Informe de Pentesting Ético

Actividad A08

Cliente: **INSECUR S.A.** — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing. Rodrigo Atilio Elgueta
Username TryHackMe: **ddjwinter**

Índice

1. Contexto de la Contratación	2
2. Datos generales	2
3. Pre-pentesting	3
4. Durante: Hallazgos por fase	3
5. Resumen ejecutivo de hallazgos	8
6. Post-pentesting: Recomendaciones	8
7. Protocolo de Contingencia	9
8. Anexos	10
9. Fuentes y bibliografía	10

1. Contexto de la Contratación

Carta de Autorización — INSECUR S.A.

Cliente: INSECUR S.A.

Contratista: Estudiante de Seguridad Aplicada a Sistemas de Información (FID-UCH).

Objeto del contrato: Servicios profesionales de Hacking Ético para elaborar un diagnóstico de seguridad y un protocolo de contingencia.

Alcance autorizado: Únicamente los entornos de laboratorio de TryHackMe asignados: *Pentesting Fundamentals*, *Basic Pentesting* y *Vulniversity*. Cualquier acción fuera de este alcance queda prohibida.

Modalidad: Individual.

Ética y Legalidad

Esta actividad se desarrolló en entornos controlados (sandbox) de TryHackMe. No se realizó ninguna acción contra sistemas reales fuera del alcance autorizado.

2. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Diego Jofré
DNI	44538375
Username TryHackMe	ddjwinter
Email institucional	jofrediego@uch.edu.ar
Sala de elección (Nivel 2)	Vulniversity
Branch en GitHub	jofre-diego
Fecha de inicio	07/10/2026
Fecha de cierre	08/10/2026

Nota metodológica sobre direcciones IP

Las bitácoras y capturas muestran distintas direcciones IP para la misma máquina (p.ej. el host de *Basic Pentesting* aparece como 10.64.154.72 en una bitácora y como 10.67.135.244 en las capturas de pantalla). Esto es esperable en TryHackMe: cada vez que se reinicia o se vuelve a desplegar una máquina de laboratorio, la plataforma asigna una IP nueva dentro del rango de la VPN. No se trata de una inconsistencia de los datos sino de sesiones distintas; se deja constancia aquí para que el docente no lo interprete como un error de bitácora.

3. Pre-pentesting

Alcance del trabajo

Dentro de alcance: las tres salas de TryHackMe asignadas (Pentesting Fundamentals, Basic Pentesting y Vulniversity), accedidas exclusivamente a través de la VPN oficial de la plataforma. Fuera de alcance: cualquier otro host, red institucional o sistema productivo.

Reglas de Enfrentamiento (ROE)

Pruebas limitadas a las IP asignadas por TryHackMe en cada sesión de VPN; sin ataques de denegación de servicio; fuerza bruta acotada a los servicios de laboratorio indicados por la sala (SSH); sin exfiltración de datos fuera del entorno de laboratorio; uso de capturas y bitácoras con sanitización de credenciales.

Autorización

Se cuenta con autorización expresa de la cátedra para operar sobre los entornos de TryHackMe indicados, en el marco de la Actividad A08.

Metodología utilizada

Se siguió el flujo de fases de PTES (Pre-engagement, Reconocimiento, Escaneo, Explotación, Post-explotación, Reporte), con apoyo del NIST SP 800-115 para la estructura de hallazgos y clasificación CWE/CVSS.

4. Durante: Hallazgos por fase

Campo	Valor
ID del hallazgo	H-01
Fase	Reconocimiento / Escaneo
Descripción	Nmap (-sC -sV) sobre el host de <i>Basic Pentesting</i> reveló SSH, HTTP y SMB/NetBIOS expuestos, ampliando la superficie de ataque disponible.
Componente afectado	Host Basic Pentesting (OpenSSH 8.2p1, Apache 2.4.41, Samba smbd 4)
Categoría (OWASP/CWE)	CWE-200 (Exposición de información a través de banners de servicio)
CVE (si aplica)	N/A
CVSS estimado	Bajo
Evidencia (captura/comando)	01-nmap-servicios-expuestos.png; <code>nmap -sC -sV <IP></code>

Herramienta utilizada	Nmap 7.99
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Minimizar banners de versión; exponer solo los puertos/servicios estrictamente necesarios; firewall por host.
Riesgo residual tras aplicar	Bajo

Campo	Valor
ID del hallazgo	H-02
Fase	Escaneo
Descripción	Gobuster identificó el directorio <code>/development</code> (HTTP 301), no enlazado desde la interfaz pública del sitio.
Componente afectado	Servicio web Apache 2.4.41 del host Basic Pentesting
Categoría (OWASP/CWE)	CWE-548 (Exposición de información mediante listado de directorios)
CVE (si aplica)	N/A
CVSS estimado	Medio (~5.3)
Evidencia (captura/comando)	02-gobuster-directorio-development.png; <code>gobuster dir -u http://<IP>-w common.txt</code>
Herramienta utilizada	Gobuster v3.8.2
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Retirar rutas de desarrollo del entorno expuesto o protegerlas con autenticación; revisar índice de contenidos publicables.
Riesgo residual tras aplicar	Bajo
Campo	Valor
ID del hallazgo	H-03

Fase	Explotación
Descripción	Ataque de fuerza bruta con Hydra contra SSH obtuvo una contraseña válida para el usuario jan , sin evidencia de bloqueo tras múltiples intentos fallidos.
Componente afectado	Servicio SSH (OpenSSH) del host Basic Pentesting
Categoría (OWASP/CWE)	CWE-307 (Restricción insuficiente de intentos de autenticación) + CWE-521 (Requisitos de contraseña débiles)
CVE (si aplica)	N/A
CVSS estimado	Alto (~ 8.1)
Evidencia (captura/comando)	bitácora hydra.txt (credencial sanitizada como [REDACTED])
Herramienta utilizada	Hydra v9.7
Impacto en la Tríada CIA	Confidencialidad, Integridad
Salvaguarda propuesta	Política de contraseñas robustas, autenticación por clave pública, fail2ban /bloqueo por intentos fallidos, MFA.
Riesgo residual tras aplicar	Medio

Campo	Valor
ID del hallazgo	H-04
Fase	Explotación
Descripción	El formulario de carga (puerto 3333) bloqueó la extensión .php (.^{Ext}ension not allowed) pero no validó variantes equivalentes como .phtml , permitiendo subir un script ejecutable del lado servidor.
Componente afectado	Aplicación web interna (Vulniversity), /internal/index.php
Categoría (OWASP/CWE)	CWE-434 (Carga de archivos sin restricción de tipo peligroso)
CVE (si aplica)	N/A
CVSS estimado	Crítico (~ 9.8)

Evidencia (captura/comando)		<code>extension_bloqueada_php.png</code> , <code>carga_archivo_shell_ok.png</code>
Herramienta utilizada		Navegador web (carga manual de webshell <code>.phtml</code>)
Impacto en la Tríada CIA		Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	pro-	Lista blanca estricta de extensiones + validación de tipo MIME/magic bytes; almacenamiento fuera del docroot; deshabilitar ejecución de scripts en el directorio de uploads.
Riesgo residual tras aplicar		Bajo
Campo		Valor
ID del hallazgo		H-05
Fase		Explotación / Post-explotación
Descripción		Al acceder vía HTTP a la webshell cargada, se recibió una conexión reversa sobre un listener Netcat, confirmando ejecución remota de código con el usuario del servicio web.
Componente afectado		Servidor web Apache 2.4.41 (puerto 3333), proceso <code>www-data</code>
Categoría (OWASP/CWE)		CWE-94 (Control inadecuado de generación de código / inyección de código)
CVE (si aplica)		N/A
CVSS estimado		Crítico (~9.8)
Evidencia (captura/comando)		<code>carga_shell_funciono.png</code> : <code>nc -nvlp 4444</code> , conexión entrante desde 10.66.147.216, <code>whoami = www-data</code>
Herramienta utilizada		Netcat
Impacto en la Tríada CIA		Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	pro-	Igual a H-04, más principio de mínimo privilegio para el usuario del servicio web, WAF y monitoreo de procesos anómalos.
Riesgo residual tras aplicar		Medio

Campo	Valor
ID del hallazgo	H-06
Fase	Post-explotación
Descripción	Desde el acceso www-data se enumeraron binarios SUID y se intentó escalar privilegios creando una unidad systemd con ExecStart para asignar SUID a /bin/bash . La captura de verificación final (whoami) devolvió un error de sintaxis de bash, por lo que el éxito de la escalada no queda confirmado en la evidencia disponible. (No logré hacerlo funcionar de manera adecuada por un error que desconozco pero el camino adecuado es el mencionado)
Componente afectado	Host Vulnversity (10.66.147.216)
Categoría (OWASP/CWE)	CWE-276 (Permisos por defecto incorrectos) / CWE-732
CVE (si aplica)	N/A
CVSS estimado	Alto potencial (~ 7.8) — no confirmado
Evidencia (captura/comando)	texto_flag.png / ultimo_paso_logrado.png — requiere repetir la prueba
Herramienta utilizada	find (SUID), systemctl
Impacto en la Tríada CIA	Confidencialidad, Integridad, Disponibilidad (si se confirma)
Salvaguarda propuesta	Revisar y eliminar binarios SUID innecesarios; restringir permisos sobre unidades de systemd de usuario; auditorías periódicas.
Riesgo residual tras aplicar	Pendiente de confirmación
Campo	Valor
ID del hallazgo	H-07
Fase	Escaneo
Descripción	Los dos hosts auditados (Basic Pentesting y Vulnversity) exponen SMB con "Message signing enabled but not required", habilitando ataques de relay NTLM/SMB.

Componente afectado	Samba smbd 4 (puertos 139/445) en ambos hosts		
Categoría (OWASP/CWE)	CWE-300 (Canal accesible por un actor no destinatario — relay)		
CVE (si aplica)	N/A		
CVSS estimado	Medio (~5.9)		
Evidencia (captura/comando)	01-nmap-servicios-expuestos.png, 03-vulnversity_escaneo_nmap.png (script smb2-security-mode)		
Herramienta utilizada	Nmap (NSE smb2-security-mode)		
Impacto en la Tríada CIA	Confidencialidad, Integridad		
Salvaguarda propuesta	pro-	Forzar firma SMB obligatoria (server signing = mandatory); segmentación de red; deshabilitar NTLM donde sea posible.	
Riesgo residual tras aplicar	Bajo		

5. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	2	H-04, H-05
Alto	2	H-03, H-06 (no confirmado)
Medio	2	H-02, H-07
Bajo	1	H-01
Total	7	H-01 a H-07

6. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. (Crítico) Corregir la validación de carga de archivos: lista blanca de extensiones + verificación de tipo MIME real, ejecución deshabilitada en el directorio de uploads (H-04, H-05).
2. (Alto) Endurecer el servicio SSH: deshabilitar autenticación por contraseña en favor de claves, agregar `fail2ban` y, de ser posible, MFA (H-03).
3. (Alto) Confirmar y remediar la escalada de privilegios vía SUID/systemd detectada de forma

parcial; limpiar binarios SUID innecesarios (H-06).

4. (Medio) Forzar firma SMB obligatoria en ambos hosts (H-07).
5. (Medio) Retirar o proteger con autenticación el directorio `/development` (H-02).
6. (Bajo) Minimizar el banner/versionado expuesto por los servicios (H-01).

Recomendaciones administrativas (políticas y procesos)

Política formal de gestión de parches; revisión periódica de superficies de ataque externas; capacitación del equipo de desarrollo en prácticas seguras de carga de archivos (OWASP ASVS); procedimiento de respuesta ante incidentes documentado y ensayado.

7. Protocolo de Contingencia

Escenario de falla

La explotación de H-04/H-05 (carga de webshell y ejecución remota de código) podría derivar en indisponibilidad del servicio web interno o en modificación/eliminación de datos si un atacante real alcanzara el mismo punto de acceso logrado en esta prueba.

Impacto sobre la continuidad del negocio

Se vería afectado el aplicativo interno de carga de archivos (puerto 3333) y, de confirmarse H-06, potencialmente la totalidad del host por compromiso a nivel root. El tiempo de afectación depende del tiempo de detección, estimado en el RTO/RPO siguiente.

Plan de respuesta

1. **Activación:** alerta por monitoreo de procesos/archivos nuevos en el directorio de uploads o por IDS de red.
2. **Contención:** aislar el host afectado de la red, revocar credenciales comprometidas (incl. usuario `jan`), eliminar el archivo cargado.
3. **Recuperación:** restaurar el servicio desde backup conocido limpio, aplicar las correcciones técnicas de la sección anterior antes de reconectar.
4. **Comunicación:** notificar a dirección de INSECUR S.A. y, si corresponde, a clientes afectados, conforme a la política interna de incidentes.
5. **Post-mortem:** documentar la cadena de explotación (H-01 a H-07) y verificar el cierre efectivo de cada hallazgo.

RTO y RPO estimados

RTO (Recovery Time Objective): 4 horas para el servicio web interno.

RPO (Recovery Point Objective): 24 horas (última copia de respaldo diaria).

Valores propuestos a título orientativo; deben ser validados y ajustados por el estudiante según los criterios de negocio asumidos para INSECUR S.A.

8. Anexos

Anexo A — Bitácora de comandos

Archivos de bitácora adjuntos: `vulniversity_nmap_puertos.txt`, `gobuster.txt`, `hydra.txt` (credencial sanitizada). Ver nota metodológica sobre IPs dinámicas en la sección de Datos Generales.

Anexo B — Capturas de pantalla

- `Kali_linux_OK.png`, `openVPN_activa_conectada_a_kali.png` — preparación del entorno.
- `01-nmap-servicios-expuestos.png`, `02-gobuster-directorio-development.png` — reconocimiento/escaneo Basic Pentesting.
- `03-vulniversity_escaneo_nmap.png` — reconocimiento Vulniversity.
- `extension_bloqueada_php.png`, `carga_archivo_shell_ok.png`, `carga_shell_funciono.png` — explotación Vulniversity.
- `hash256.png`, `texto_flag.png`, `ultimo_paso_logrado.png` — post-explotación Vulniversity.

Anexo C — Hashes de las flags obtenidas

```

1 # Formato: flag_id    sha256_hash
2 H-flag-user(bill)    8bd7992fbe8a6ad22a63361004cfcedb
3 H-flag-root          a58ff8579f0a9270368d33a9966c7fd5

```

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Diego Daniel Jofre Winterstetter

09/10/2026

Firma del estudiante

Fecha

9. Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals*: [sala oficial](#)
- TryHackMe. *Basic Pentesting*: [sala oficial](#)
- TryHackMe. *Vulniversity*: [sala oficial](#)
- OWASP Foundation. *Web Security Testing Guide (WSTG)*: [sitio oficial](#)
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- MITRE. *Common Weakness Enumeration (CWE)*: cwe.mitre.org